SEMANA 11 · UNIDAD 2 · SEGURIDAD EN REDES

Repaso Unidad 2

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 11 · Periodo 2026-2 · Barranquilla, Colombia

PARTE 1 DE 4 · MAPA DE LA UNIDAD 2

Cifrado · Identidad · Monitoreo · Vulnerabilidades

MAPA

De dónde venimos y qué haremos en este repaso

Cuatro semanas de defensa consolidadas en cuatro bloques de práctica.

14–20 sep — 7 — Cifrado en tránsito
TLS · VPN · IPsec

21–27 sep — 8 — Identidad y acceso
MFA · mínimo privilegio

28 sep–4 oct — 9 — Monitoreo y logging
SIEM · IDS/IPS

12–18 oct — 10 — Vulnerabilidades
CVE · escaneo · parche



Parte 1 · Mapa conceptual

las cuatro semanas
en una sola vista

salida: el hilo conductor



Parte 2 · Cifrado e identidad

ejercicios con
retroalimentación

salida: TLS, PKI, MFA, ZT



Parte 3 · Monitoreo y vulneras

logs, reglas, escaneo
y priorización

salida: evidencia defendible



Parte 4 · Caso integrador

cadena de ataque
ficticia del Caribe

salida: autoevaluación

Sin tema nuevo: consolidar, practicar y verificar

Diagrama propio · plan de la semana: docs/analisis-tematico.md §2.4

La defensa en capas: cada control responde una pregunta

No son cuatro temas sueltos: son cuatro respuestas a la misma cadena de riesgo.

RIESGO COMPARTIDO DE LA UNIDAD: alguien no autorizado accede, observa o altera información en la red

Cada capa reduce una parte distinta de ese riesgo; ninguna sola lo elimina

1 · Cifrado

¿Puede leerlo o alterarlo en el camino?

confidencialidad e integridad en tránsito

TLS · VPN · IPsec

2 · Identidad

¿Quién es y qué le está permitido?

autenticación, autorización, ZT

MFA · RBAC/ABAC · PDP

3 · Monitoreo

¿Alguien lo detectó a tiempo?

evidencia, correlación, detección

syslog · SIEM · IDS/IPS

4 · Vulnerabilidades

¿Qué grieta quedó abierta y cuándo cerrarla?

descubrimiento, priorización, parche

CVE · CVSS · escaneo

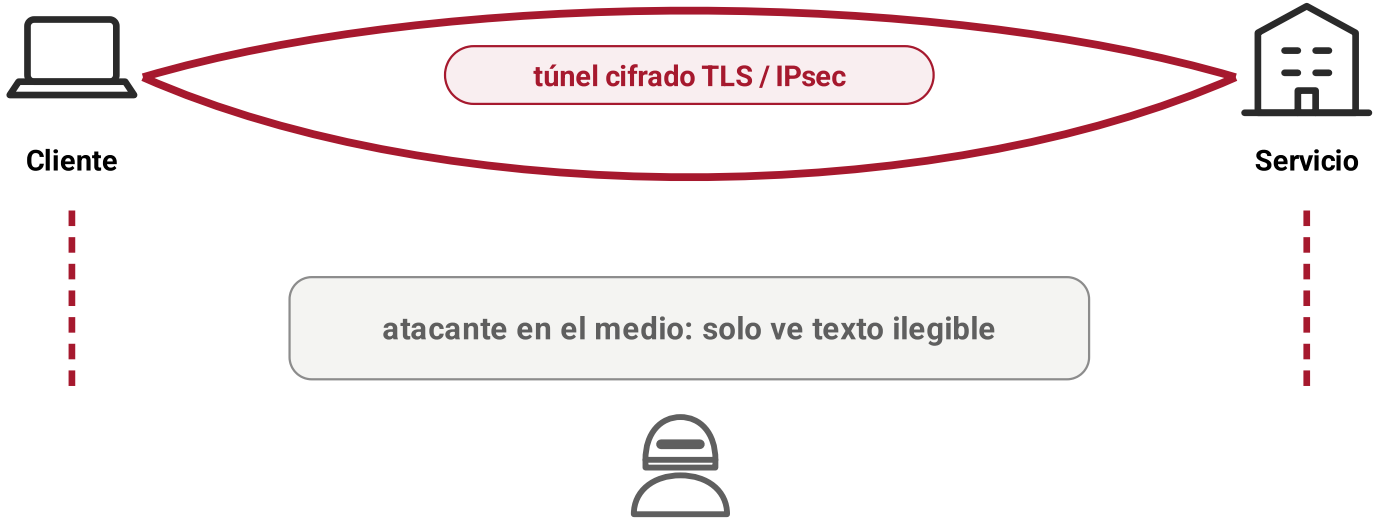
IDEA DE LA UNIDAD: si una capa falla, la siguiente es la que avisa o frena

Por eso un mismo incidente se analiza siempre con las cuatro preguntas encadenadas

Diagrama propio · concepto: NIST SP 800-53 Rev.5 (2020), familias de controles

Cifrado en tránsito: el túnel que protege la conversación

TLS en el navegador, IPsec y WireGuard en la red; el principio es el mismo.



Tres túneles, un patrón

- **TLS 1.3** (RFC 8446): navegador a servidor, puerto 443.
- **IPsec** (RFC 7296): sitio a sitio o cliente a sitio, en la capa de red.
- **WireGuard**: túnel ligero por llaves, alternativa moderna.

No protege: lo que el usuario escribe *antes* de que el túnel empiece, ni a un extremo ya comprometido.

Lo que aporta el túnel

· Confidencialidad: nadie en el medio lee el contenido.

· Integridad: cualquier alteración se detecta al descifrar.

· Autenticación del extremo: certificado o llave pública validada.

IETF RFC 8446 (2018), §2 · Diagrama propio

Qué cubre el cifrado y qué queda fuera del túnel

Leer bien el alcance evita confiar en un control para lo que no sirve.

DENTRO DEL TÚNEL

- El contenido de la página o del archivo que viaja
- Las credenciales enviadas después del saludo TLS
- Los datos personales del formulario ya enviado
- La integridad: un bit alterado rompe el descifrado

Pregunta de verificación

¿el candado del navegador está cerrado y el certificado es válido?

confidencialidad e integridad en el camino

FUERA DEL TÚNEL

- El phishing: el usuario entrega la clave en el sitio falso
- El extremo comprometido: el malware lee lo ya descifrado
- Los metadatos: IP de destino, hora, tamaño del paquete
- La mala configuración: versión obsoleta o llave débil

Pregunta de verificación

¿quién quedó del otro lado y qué versión negocia el servicio?

aquí entran identidad, monitoreo y parches

Diagrama propio · concepto: NIST SP 800-52 Rev.2 (2019), §3

Identidad como perímetro: el punto de decisión en el centro

En confianza cero, cada solicitud pasa por una evaluación antes de tocar el recurso.



QUÉ EVALÚA EL PDP ANTES DE DECIDIR

· **Identidad:** ¿la autenticación fue multifactor y reciente?

· **Dispositivo:** ¿está gestionado y con parches al día?

· **Contexto:** ¿hora, ubicación y patrón de acceso son normales?

· **Política:** ¿qué modelo de autorización lo permite y con qué límites?

La decisión no es única: se reevalúa durante la sesión. De ahí el nombre de confianza cero.

Del factor de autenticación al mínimo privilegio

Tres piezas de la semana ocho: factores, modelos de autorización y privilegio temporal.

FACTORES DE AUTENTICACIÓN

- algo que sé · clave, PIN
- algo que tengo · llave física, móvil
- algo que soy · huella, rostro

MFA = combinar factores distintos

MODELOS DE AUTORIZACIÓN

RBAC · por rol
contable ve reportes; no ve configuración

ABAC · por atributo
solo desde la red de la oficina y en horario

RBAC fija quién; ABAC añade cuándo y desde dónde

PRIVILEGIO MÍNIMO Y TEMPORAL

- solo el permiso necesario
- solo por el tiempo requerido
- acceso justo a tiempo (JIT)

menos tiempo de exposición, menos daño

CADENA COMPLETA DE LA SEMANA 8

Primero pruebo quién es (factores + MFA) · después decido qué puede hacer (RBAC + ABAC)

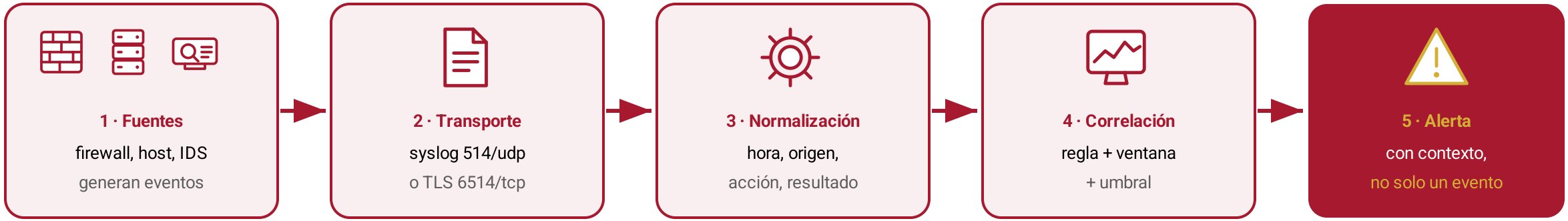
y el privilegio dura lo mínimo (mínimo privilegio + JIT)

Si la identidad es sólida, el cifrado protege el canal y el monitoreo vigila el resto

NIST SP 800-63B (2017), §5 · Diagrama propio

Monitoreo: del evento crudo a la alerta defendible

La misma cadena de siempre: fuente, transporte, normalización, correlación, alerta.



LO QUE SUMAN LAS TRES TECNOLOGÍAS DE LA SEMANA 9

· **Suricata** aplica firmas sobre el tráfico: lo conocido, en tiempo real, alerta o bloquea.

· **Zeek** describe la conversación sin juzgar: registros de conexión y de protocolo para el análisis.

· **El SIEM** correlaciona eventos de todas las fuentes y sostiene la investigación con contexto.

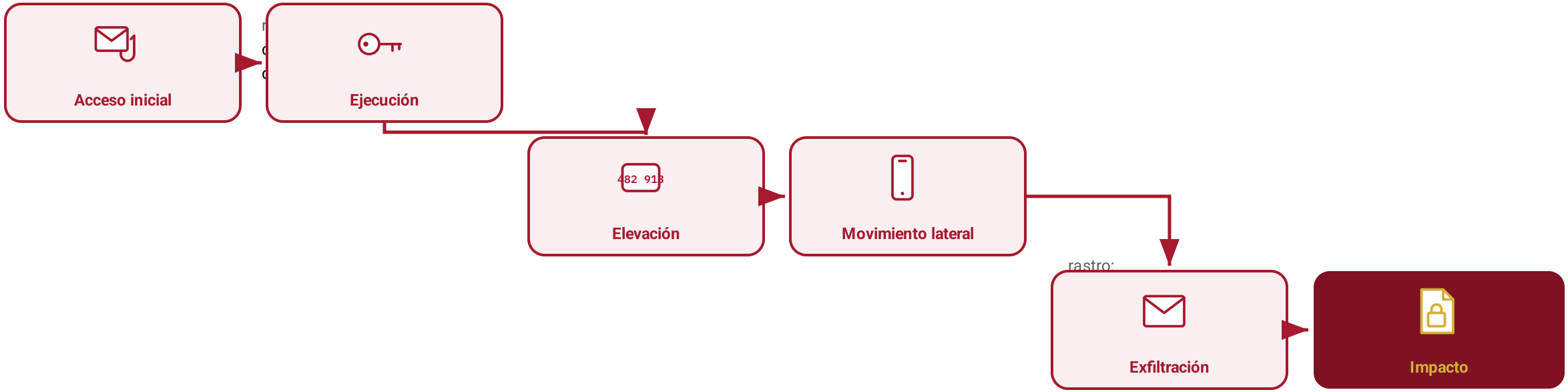
· **El flujo NetFlow/IPFIX** aporta el quién habló con quién, cuánto y cada cuándo, sin mirar el contenido.

Una alerta sin contexto obliga a investigar desde cero; con contexto, se puede decidir en minutos.

NIST SP 800-92 (2006), §2 · Diagrama propio

Qué mira el monitoreo: del acceso inicial a la ejecución

Cada táctica del atacante deja un rastro distinto en la red y en la bitácora.



CUANTO ANTES SE DETIENE LA CADENA, MENOS CAPAS Toca ARRIESGAR EL ATACANTE

El monitoreo busca el rastro de cada salto: correo, proceso, sesión elevada, conexión lateral, volumen de salida

Diagrama propio · concepto: MITRE ATT&CK® Enterprise (matriz de tácticas)

Vulnerabilidades: el ciclo que nunca se detiene

Descubrir, priorizar, parchar, verificar; el anillo se repite cada vez que sale un CVE.



VOCABULARIO DE LA SEMANA 10

· **CVE**: identificador público único del hallazgo · **CWE**: el tipo de error de diseño o código · **NVD**: el catálogo donde se consulta

· **CVSS**: severidad técnica · **EPSS**: probabilidad de explotación · **KEV**: catálogo de explotación confirmada · **escaneo**: autenticado o no

NIST SP 800-40 Rev.4 (2022), §2 — Ciclo de gestión

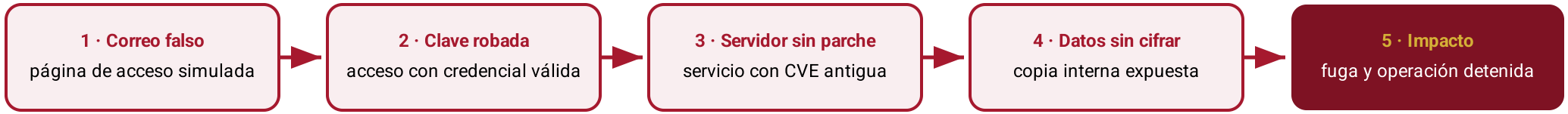
Severidad, explotación y contexto: tres ejes, una fila

Un hallazgo crítico sin explotación no es lo mismo que uno medio activamente explotado.



Las cuatro capas frente a una misma cadena de ataque

Cada control habría cortado el mismo incidente en un punto distinto.



DÓNDE HABRÍA PARADO LA CADENA CADA CAPA DE LA UNIDAD 2

Identidad (S08)
MFA habría bloqueado el acceso

Monitoreo (S09)
la alerta de acceso inusual avisa al SOC

Vulnerabilas (S10)
el parche cerraba la grieta de nivel

Cifrado (S07)
la copia viajaba ilegible o no salía

CON DEFENSAS EN CAPAS, EL PASO 5 NUNCA SE ALCANZA

La defensa en profundidad no elimina el riesgo: multiplica las oportunidades de cortar la cadena

LA PREGUNTA INTEGRADORA DEL REPASO

Dados un incidente y su relato, ¿en qué paso de la cadena se habría cortado con cada control de la unidad?

Y a la inversa: si una capa no estaba, ¿qué evidencia habría faltado para reconstruir lo sucedido?

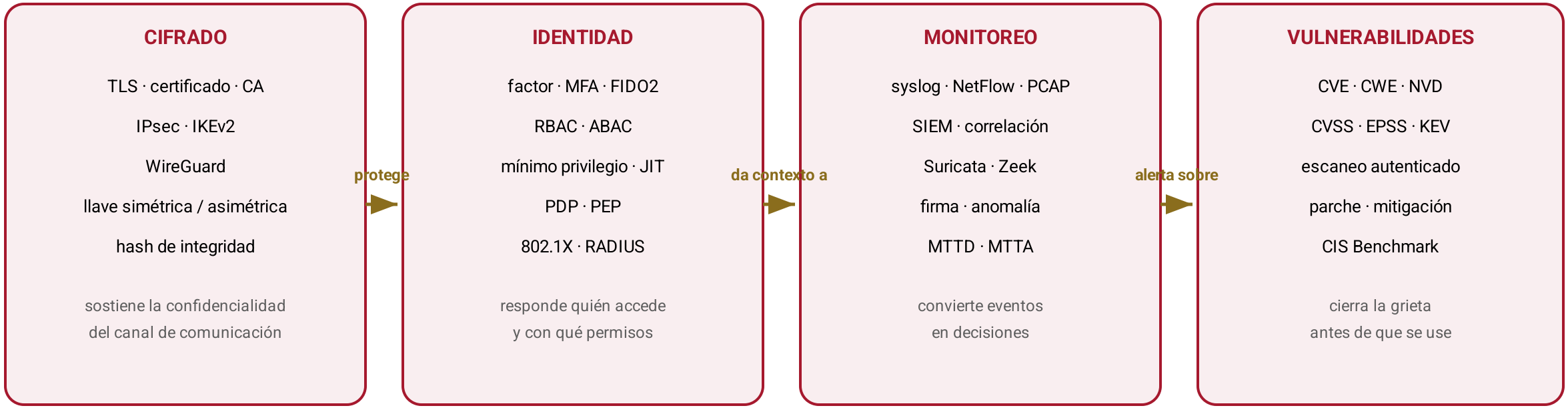
Esta pregunta recorre las cuatro semanas y aparece en todos los ejercicios de las partes siguientes

Diagrama propio · concepto: MITRE ATT&CK® Enterprise y NIST SP 800-61 Rev.2 (2012)

VOCABULARIO

Mapa de conceptos: cómo se enlazan los términos clave

Los términos no viven sueltos: cada uno apoya a su vecino.



SI ALGUIEN PREGUNTA QUÉ ESTUDIA LA UNIDAD 2, LA RESPUESTA ES ESTE MAPA

Cuatro columnas con sus términos y, sobre todo, las flechas: protege, da contexto, alerta sobre

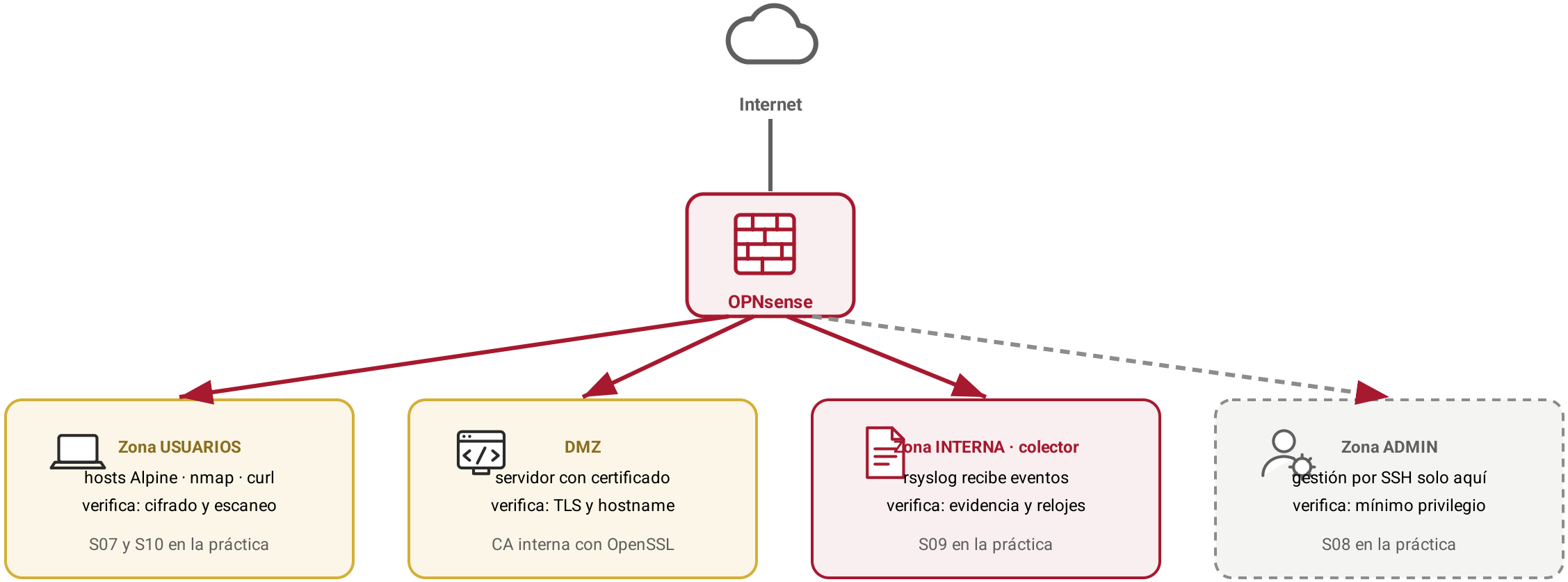
Si recuerda las columnas pero no las flechas, todavía falta el hilo que une la unidad

Diagrama propio · mapa de conceptos de la Unidad 2

PLATAFORMA

Dónde se practicó cada tema y dónde verificar hoy

La misma topología del laboratorio sostiene el repaso completo de la unidad.



máquina virtual con OPNsense · anfitrión VirtualBox · salas gratuitas de TryHackMe para identidad y explotación

Diagrama propio · topología del Laboratorio 1 del curso

SÍNTESIS

Lo que queda de la Parte 1

Tres ideas para llevar al resto del repaso.

1 · Cuatro preguntas

¿se lee en el camino? ¿quién es?
¿alguien lo vio? ¿qué grieta quedó?

siempre en ese orden

2 · Cadenas, no listas

handshake, correlación, ciclo:
cada concepto tiene su secuencia

el orden es el examen del concepto

3 · Verificar, no confiar

el laboratorio del curso permite
comprobar cada idea con un comando

y una salida que se lee

EN LA PARTE 2 EMPEZAMOS A PRACTICAR: CIFRADO E IDENTIDAD

Cada ejercicio trae su escenario, sus pistas y la resolución en la diapositiva siguiente

Consejo: pause el video, intente resolver antes de avanzar

Diagrama propio · síntesis de la Parte 1

PARTE 2 DE 4

2

Ejercicios de cifrado e identidad

Semana 11 · Repaso Unidad 2

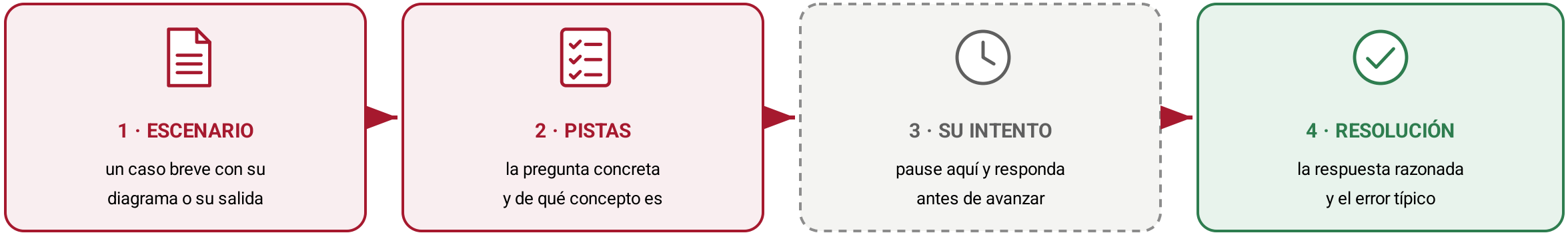
TLS PKI VPN Control de acceso

CUC UNIVERSIDAD DE LA COSTA

MÉTODO

Cómo resolver los ejercicios de este repaso

Cada ejercicio tiene escenario, pistas y resolución; el intento propio viene antes.



POR QUÉ ESTE MÉTODO

Un repaso que solo escucha no prepara para un examen práctico: hay que manipular el concepto

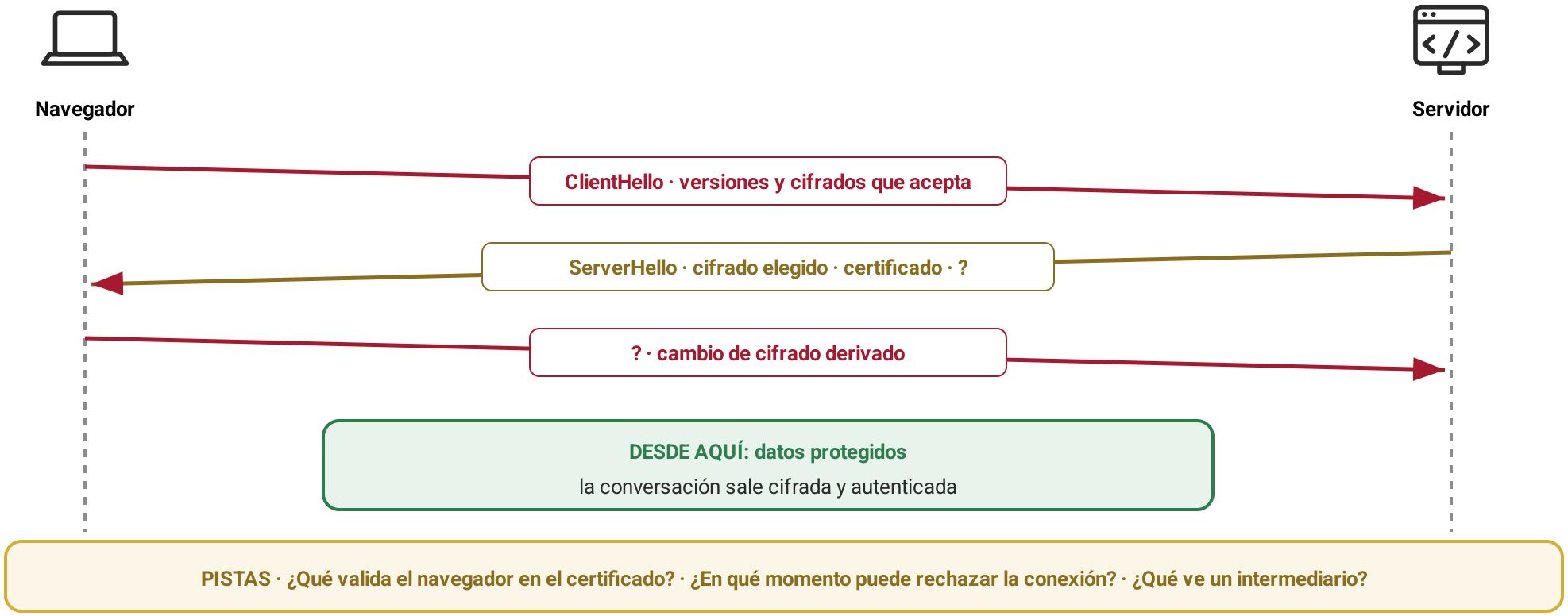
El error que usted cometa al intentar es el que más se corrige; por eso la resolución siempre explica también el tropiezo

Seis ejercicios en esta parte: tres de cifrado y tres de identidad

Diagrama propio · método de repaso del curso

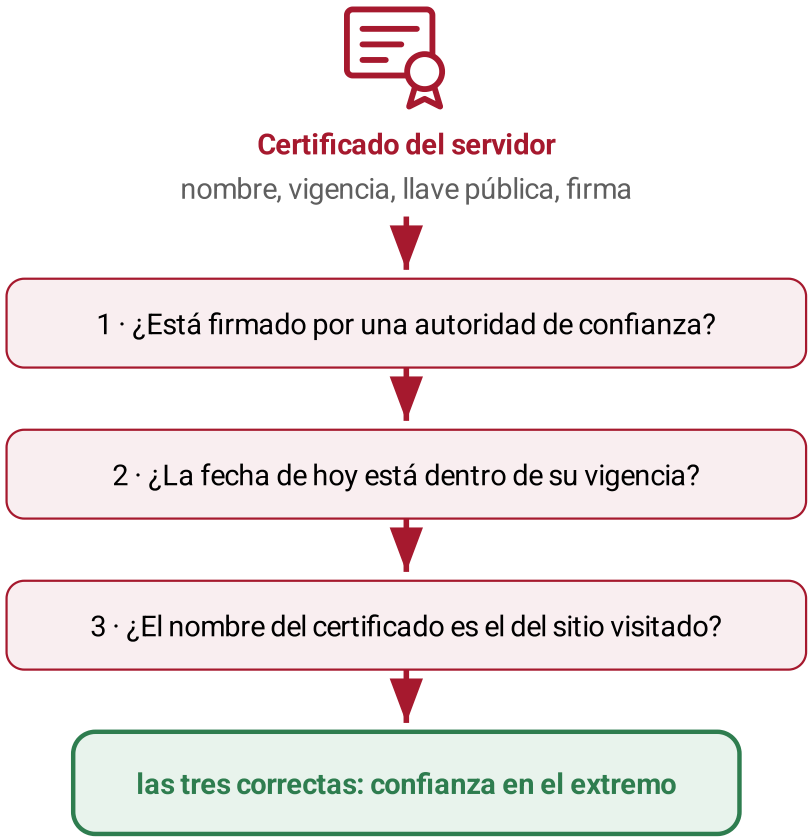
Leer un saludo de TLS: ¿qué verifica el cliente y cuándo?

Escenario: el navegador negocia con un servidor; dos flechas están sin etiquetar.



El navegador valida cadena, vigencia y nombre

Tres verificaciones encadenadas; si una falla, la conexión no avanza.



Respuestas

- Flecha 2: **Finished** del servidor, con el cambio de cifrado ya derivado.
- Flecha 3: **Finished** del cliente; ambos confirman la clave derivada.
- Valida: cadena de firmas, vigencia y coincidencia del nombre.

Error típico: fijarse solo en el candado y no en el nombre; un certificado válido para otro dominio sigue mostrando candado.

Anatomía de un certificado: encuentre los campos críticos

Escenario: un certificado con siete zonas marcadas; identifique cuáles impiden el engaño.

A · Sujeto y nombre (CN y SAN)
para quién es · nombres alternos que también valen

B · Emisor (autoridad de certificación)
quién responde por la autenticidad del certificado

C · Vigencia (no antes de / no después de)
la ventana en la que el certificado es válido

D · Llave pública y algoritmo
la que el navegador usa para autenticar y derivar

E · Extensiones (uso de llave, SAN, CRL)
restringe para qué sirve y cómo se revoca

F · Firma digital del emisor
sellado que nadie más puede producir

G · Huella del certificado anterior
enlaza con la cadena hasta la raíz

PISTA

El engaño del intermediario falla cuando un campo no coincide con la realidad

IETF RFC 5280 (2008), §4.1 — Especificación del certificado X.509

Nombre, vigencia y revocación: la tríada anti-engaño

Un certificado real pero de otro sitio falla en el nombre; uno robado, en la revocación.

ESCENARIO A · certificado de otro dominio

CN: otrositio.com · SAN: otrositio.com

↓

usted visita: tienda.com.co

↓

el nombre no coincide
el navegador detiene la conexión

veredicto: el campo A protege aquí
candado no significa sitio correcto

ESCENARIO B · certificado robado y revocado

CN correcto · cadena y vigencia correctas

↓

la autoridad lo revocó: aparece en la lista de revocación

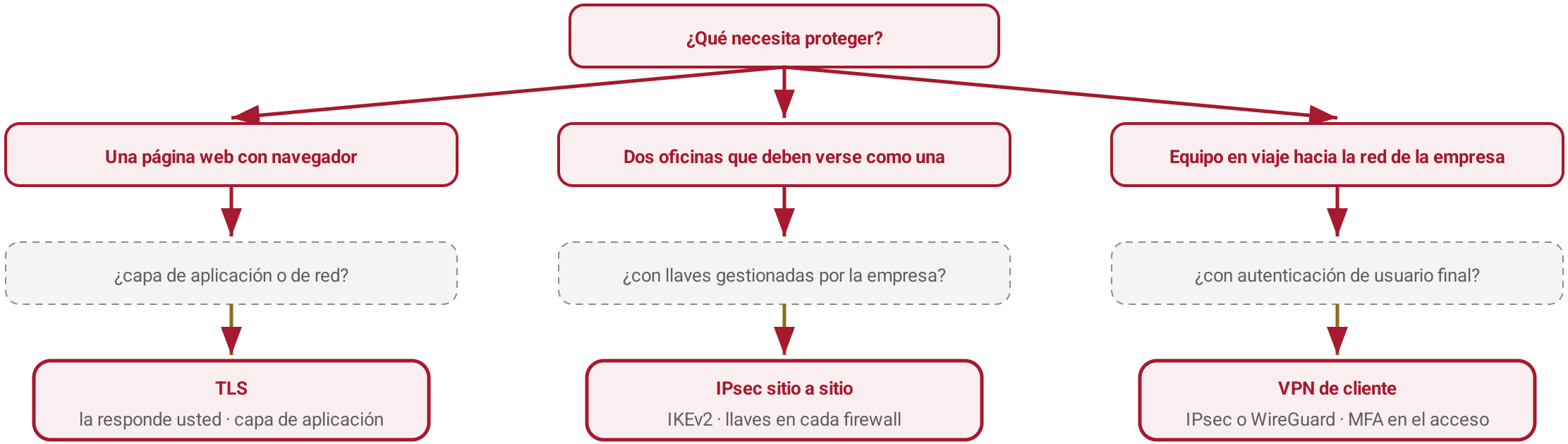
↓

la verificación de revocación lo detecta
o el servicio emisor lo reporta como inválido

veredicto: los campos E y F protegen aquí
la revocación es la red de seguridad

Elija el túnel: tres escenarios, tres respuestas

Árbol de decisión: uso, extremos y quién administra la llave.



PISTA · En los tres casos: ¿quién tiene la llave, quién autentica y qué pasa si el extremo se cae?

Diagrama propio · IETF RFC 7296 (2014) · WireGuard whitepaper (2017)

La elección correcta depende de los extremos, no de la marca

Mismo patrón de túnel; cambian la capa, la administración de llaves y la autenticación.

TLS · aplicación

extremos: navegador y servidor

llave: el servidor, con su certificado

autentica: el certificado del sitio

si un extremo cae: la página no carga

elegido para: comercio, banca, correo web

no protege: otras aplicaciones de la red

IPsec sitio a sitio · red

extremos: dos firewalls

llave: precompartida o por IKEv2

autentica: las llaves de cada extremo

si un extremo cae: cae la oficina remota

elegido para: sucursales, centro de datos

transparente: el usuario no lo nota

Cliente · IPsec o WireGuard

extremos: equipo portátil y firewall

llave: por dispositivo, con MFA

autentica: usuario final más dispositivo

si un extremo cae: pierde solo el viajero

elegido para: teletrabajo, viajeros

WireGuard: menos parámetros, más ligero

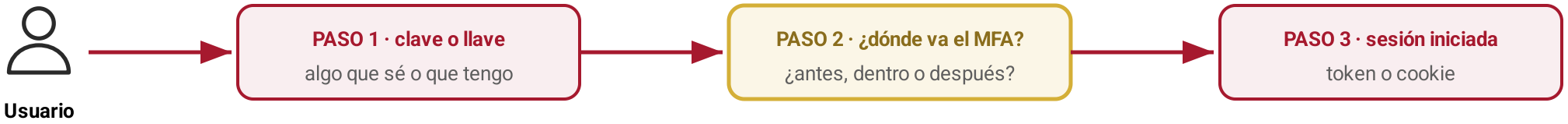
ERROR TÍPICO: elegir por la marca del producto y no por la capa, la llave y la autenticación

Los tres son túneles correctos; el incorrecto es el que no corresponde a quién se conecta con quién

Diagrama propio · IETF RFC 8446 (2018), RFC 7296 (2014), WireGuard (2017)

Ubique el MFA: dónde se inserta en el acceso y qué aporta

Escenario: un login con clave; marca con una X el punto donde entra el segundo factor.



OBSERVACIÓN: el usuario recibe un código de seis dígitos por mensaje y lo digita en la misma página donde puso la clave

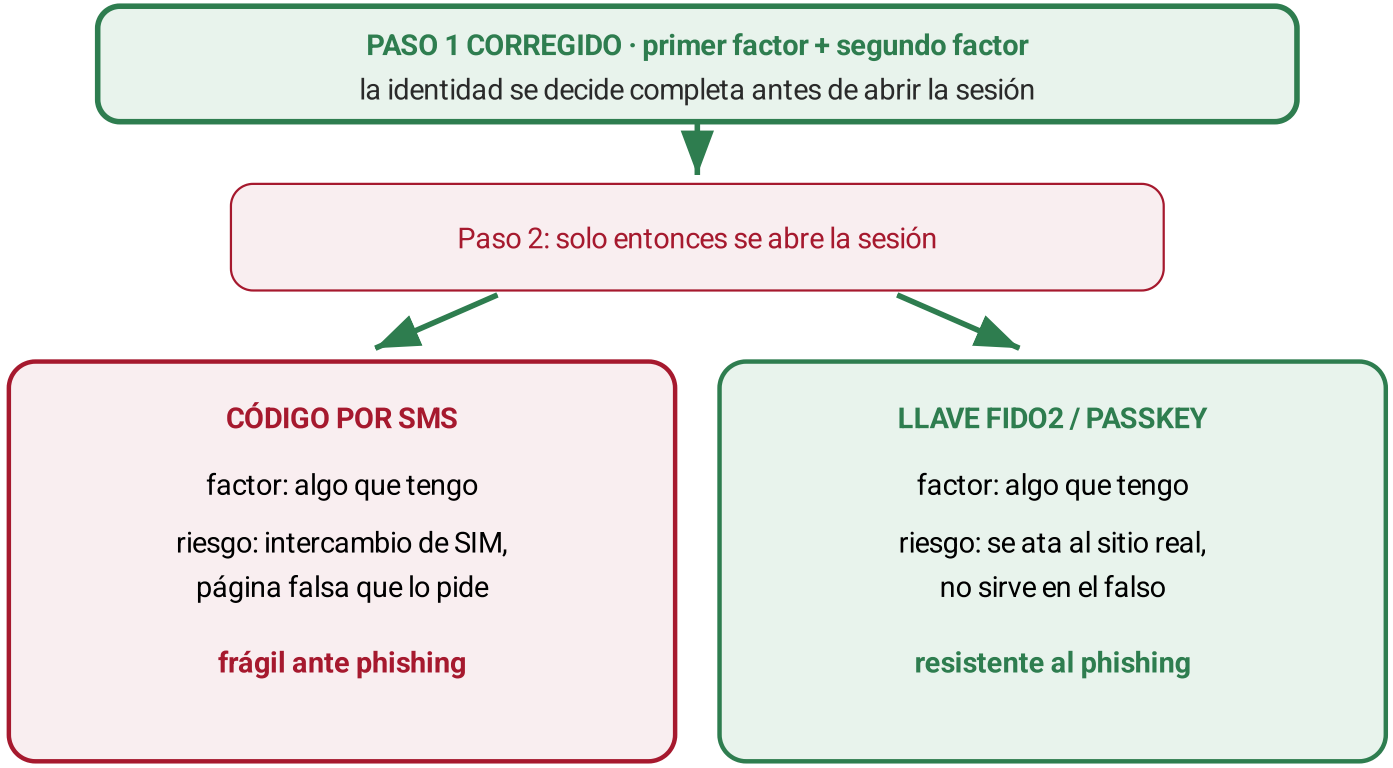
PISTAS

· ¿El código protege contra un keylogger o contra un sitio falso que lo pide?

· ¿Qué factor es el código de seis dígitos y qué lo hace frágil?

El MFA va en el paso 1; los códigos por SMS son el eslabón frágil

Combinar factores distintos; cuanto más vinculado al canal, más resistente.



Respuestas

- El MFA va **en el paso 1**, completando la identidad antes de la sesión.
- El código de seis dígitos es factor de posesión, pero **viaja por el mismo canal** que la clave.
- Un sitio falso que pide ambos lo obtiene completos.

Regla: si el segundo factor puede entregarse a un tercero, ya no es un factor: es un trámite.

NIST SP 800-63B (2017), §5.1.3 y §5.2.3 — MFA y llaves resistentes al phishing

RBAC o ABAC: asigne el modelo a tres empleados

Escenario: tres solicitudes; decida con qué modelo se aprieban mejor.

SOLICITUDES DEL DÍA DE HOY

Solicitud A

La contable del turno día

consulta el reporte de ventas

¿modelo por rol o por atributo?

¿qué permiso exacto?

Solicitud B

Un administrador de red

pide SSH al firewall a las tres de la mañana

¿qué condición adicional conviene?

¿permiso permanente o temporal?

Solicitud C

Un contratista externo

necesita un archivo por tres días

¿qué modelo y qué límite de tiempo?

¿quién aprueba la excepción?

PISTA · El modelo por roles responde quién; el modelo por atributos añade cuándo, desde dónde y por cuánto tiempo

Y en todos los casos vale el mínimo privilegio: el permiso más pequeño que resuelve la solicitud

Roles para lo previsible; atributos y tiempo para lo excepcional

Los tres casos resueltos; el denominador común es el privilegio mínimo y temporal.

A · Rol

modelo: RBAC

permiso: leer reportes de ventas

por qué: el rol contable ya implica esa responsabilidad

sin atributos adicionales: es lo previsible de cada día

B · Atributos + tiempo

modelo: ABAC sobre el rol admin

condición: ventana de cambio y registro de sesión obligatorio

tiempo: acceso justo a tiempo

la hora inusual no bloquea: dispara registro y revisión

C · Excepción temporal

modelo: atributo de vigencia

permiso: un solo archivo, un solo destino, tres días

aprobación: responsable del activo

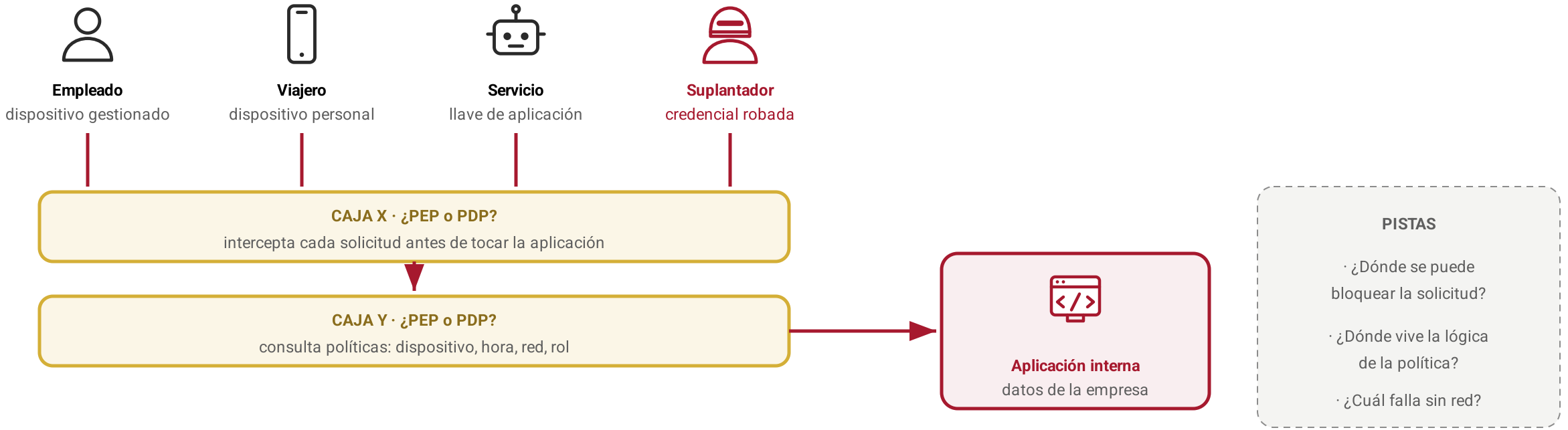
al vencer, el permiso desaparece solo

ERROR TÍPICO: dar rol permanente para resolver una excepción de tres días

El privilegio que dura más de lo necesario es una vulnerabilidad con fecha de expiración olvidada

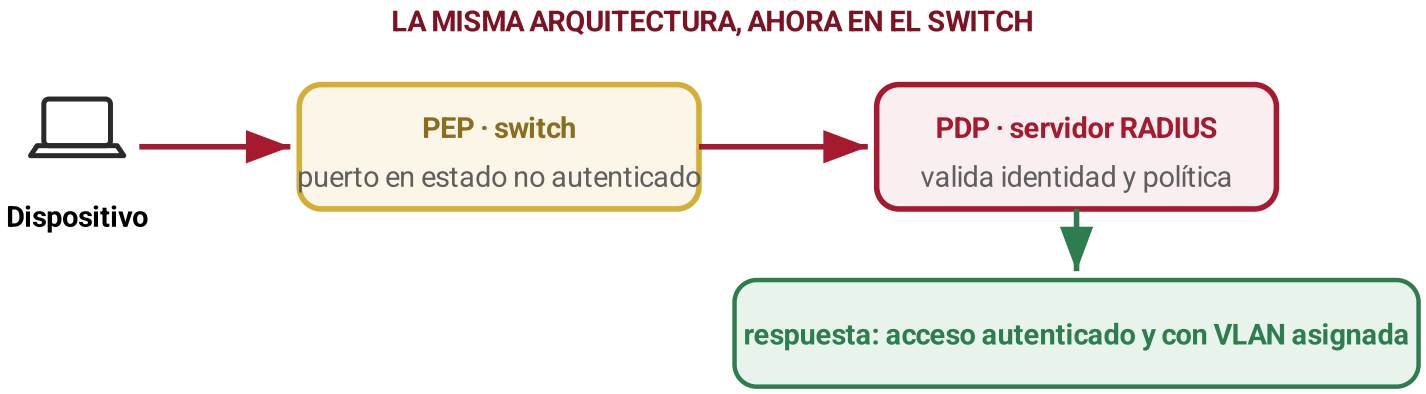
Confianza cero: ubique el PDP y el PEP en la topología

Escenario: cuatro accesos posibles a una aplicación; dos cajas están sin etiquetar.



El PEP bloquea; el PDP decide; y el puerto es el primer PEP

La misma lógica se aplica al cable: 802.1X es confianza cero en la capa de enlace.



SECUENCIA EAP-TLS, PASO A PASO

1 · El switch ve el cable y pide identidad, sin dar acceso todavía

2 · El cliente entrega su certificado; el servidor RADIUS lo valida

3 · Si es válido, el puerto abre y asigna la VLAN de la política

Respuestas

- Caja X = **PEP**: intercepta y puede bloquear.
- Caja Y = **PDP**: decide con base en la política.
- El suplantador se queda en el PEP: credencial robada sin segundo factor no pasa.

Puente a la práctica: en el switch del laboratorio, un puerto sin autenticar solo ve la red de invitados.

SÍNTESIS

Lo que queda de la Parte 2

Seis ejercicios, dos familias, una idea por familia.

CIFRADO · lo que se repite

Leer el saludo, validar cadena, vigencia y nombre;
elegir el túnel por capa, llave y autenticación.

Si un certificado no coincide con el sitio, el candado no salva.

IDENTIDAD · lo que se repite

Completar la identidad antes de la sesión; combinar
roles con atributos y expirar lo excepcional.

El segundo factor que viaja por el mismo canal no es un factor.

EN LA PARTE 3: MONITOREO Y VULNERABILIDADES, CON LA MISMA DINÁMICA

Leer una bitácora, decodificar una regla, separar abierto de filtrado y priorizar sin miedo a la severidad

Diagrama propio · síntesis de la Parte 2

PARTE 3 DE 4

3

Ejercicios de monitoreo y vulnerabilidades

Semana 11 · Repaso Unidad 2

Logs | Reglas | Escaneo | Priorización

CUC UNIVERSIDAD DE LA COSTA

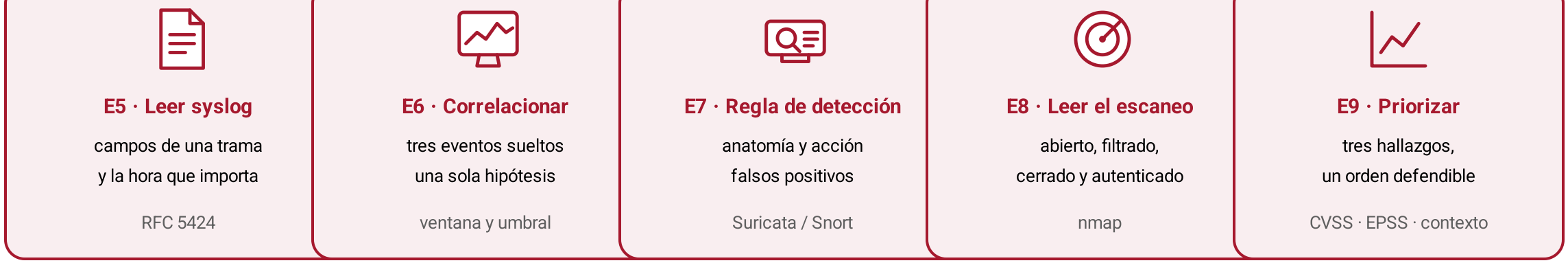
MAPA

De dónde venimos y qué veremos en esta parte

Cinco ejercicios de lectura y dos mapas de errores frecuentes.

PARTE 3 · EJERCICIOS DE MONITOREO Y VULNERABILIDADES

Aprender a leer lo que la red ya produce: bitácoras, reglas, escaneos y prioridades



CIERRE DE LA PARTE: LOS ERRORES FRECUENTES DE ESTAS DOS SEMANAS

Después de los cinco ejercicios, consolidamos los tropiezos que más se repiten en la práctica

Diagrama propio · plan de la Parte 3

Leer una trama de syslog: ¿qué cuenta y en qué orden?

Escenario: una trama realista; señale el campo que identifica al emisor y el que fija la hora.

<134>1 2026-10-13T09:15:04-05:00 fw-zona-dmz filterd 8231 - - Port scan detected from 10.10.10.66

prioridad | marca de tiempo con zona | nombre del equipo

LOS SEIS CAMPOS OBLIGATORIOS DE LA TRAMA, EN ORDEN

1 · **Prioridad** entre signos menor y mayor: facility por ocho más severidad. Aquí, 134.

2 · **Marca de tiempo** con zona horaria explícita: 2026-10-13, nueve y quince, con desfase menos cinco.

3 · **Nombre del equipo** que emite: fw-zona-dmz. Este es el identificador del emisor.

4 · **Proceso y identificador**: filterd, 8231. Ayuda a separar múltiples instancias del mismo servicio.

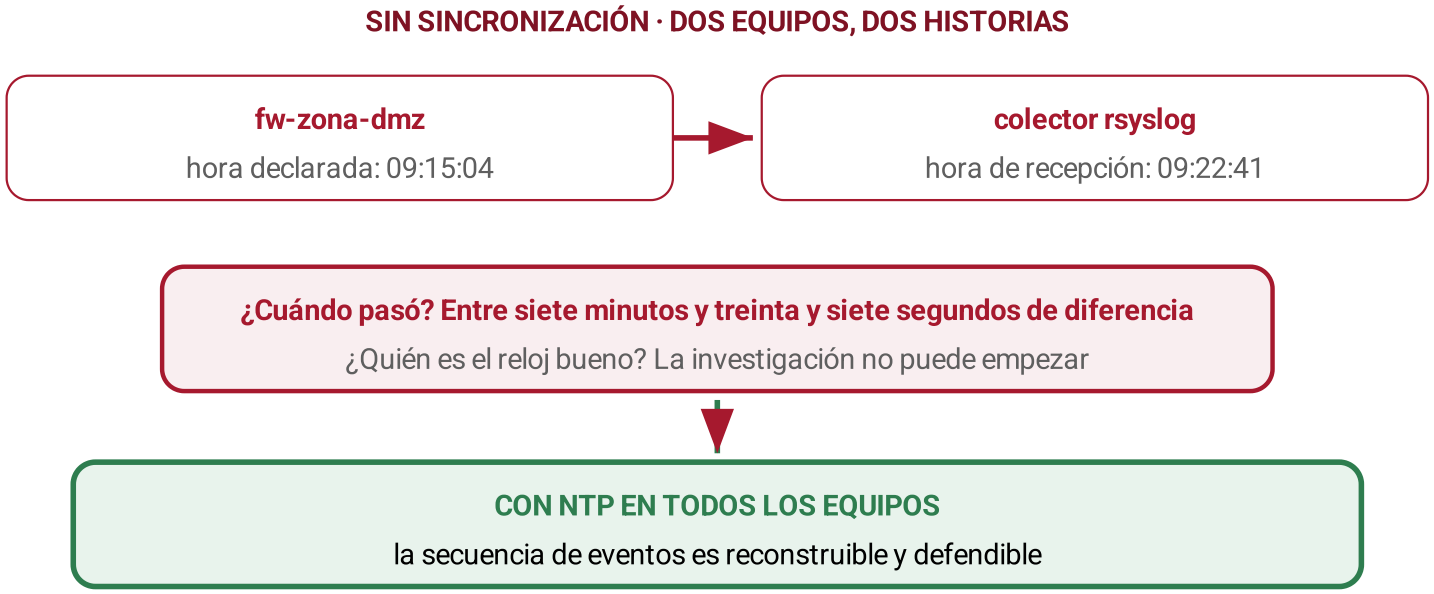
5 · **Banda estructurada** o guion: aquí sin estructura, solo el mensaje libre.

6 · **Mensaje**: el escaneo de puertos detectado desde una dirección de la red de usuarios.

IETF RFC 5424 (2009), §6 — Formato de la trama de syslog

El emisor es el nombre del equipo; la credibilidad, la hora

Sin relojes sincronizados, la bitácora deja de ser prueba y se vuelve opinión.



La hora del emisor viaja en la trama; la hora de recepción la pone el colector. Las dos deben hablar el mismo reloj.

Respuestas

- Identificador del emisor: el **nombre del equipo**, fw-zona-dmz.
- Hora que fija el evento: la **marca de tiempo de la trama**, con su zona horaria.
- Para correlacionar, combine emisor más mensaje y ventana de tiempo.

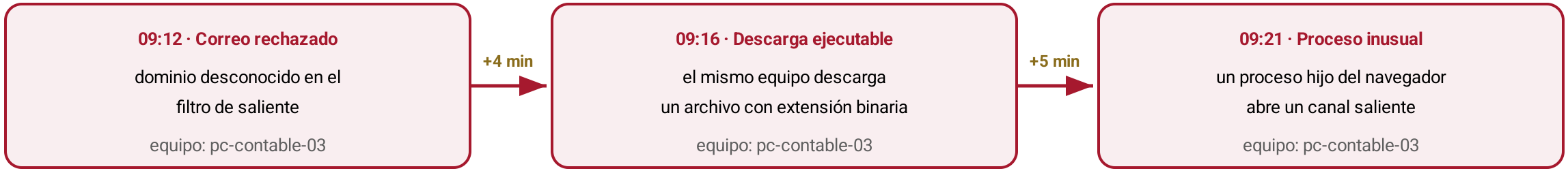
Error típico: confiar en la hora del equipo sin verificar que esté sincizado; toda la correlación se desordena.

IETF RFC 5424 (2009), §6.2 · NIST SP 800-92 (2006), §4.3 — Sincronización

EJERCICIO 6 · MONITOREO

Tres eventos sueltos, una hipótesis: cruce el hilo

Escenario: tres alertas de la mañana; descubra qué las conecta dentro de la ventana.



LA HIPÓTESIS QUE USTED DEBE FORMULAR

Las tres alertas comparten equipo y quedan dentro de una ventana de diez minutos.

Una sola de ellas puede ser ruido; las tres en secuencia describen una cadena.

Pistas: ¿qué buscó primero el atacante? · ¿qué recibió el usuario? · ¿qué abrió el equipo?

Diagrama propio · concepto: regla de correlación (NIST SP 800-92, 2006), §3.3

La correlación une por emisor, tiempo y patrón, no por un solo campo

Tres alertas, una cadena; la ventana de tiempo es la que da sentido a la historia.

Reconocimiento y entrega

el correo externo busca al usuario

el filtro lo rechaza, pero la intención quedó registrada

→

Descarga

el ejecutable llega por otra vía

sin verificar en la pasarela de archivos

→

Ejecución y canal

el proceso hijo confirma la ejecución

el canal saliente, la comunicación

REGLA DE CORRELACIÓN QUE DISPARA LA ALERTA DE NIVEL ALTO

SI mismo emisor Y tres eventos de la cadena Y ventana de diez minutos

ENTONCES alerta elevada al analista con las tres evidencias adjuntas

ERROR TÍPICO: mirar cada alerta por separado y cerrarlas una a una

La correlación es lo que convierte tres avisos molestos en una investigación

Diagrama propio · concepto: MITRE ATT&CK® Enterprise — Reconocimiento, entrega, ejecución

Anatomía de una regla: identifique la acción y el disparador

Escenario: una regla de detección con cinco campos rotulados.

```
alert http $HOME_NET any - $EXTERNAL_NET any (msg:"EXE download"; file.data; content:".exe"; sid:1000001; rev:3;)
```

LOS CINCO COMPONENTES DE UNA REGLA, EN SU ORDEN DE LECTURA

1 · Acción

alert, drop, pass…

¿qué hace el sensor cuando coincide?

aquí: solo avisa

2 · Cabecera

protocolo, origen, puerto, destino

http, red interna hacia la externa

3 · Opciones

msg, content, file.data, sid

el disparador: la extensión .exe

4 · Identificador

sid único

rev: versión

permite seguir la evolución de la regla

PISTA

Si el disparador es amplio, la regla alertará demasiado

¿qué la estrecha?

Afinar es acotar el disparador sin romper la detección

Tres ajustes típicos y el precio de cada uno si se exagera.

DE LA REGLA AMPLIA A LA REGLA AFINADA

AMPLIA · cualquier .exe en cualquier descarga

incluye actualizadores legítimos y firmwares

→

AFINADA · solo desde hosts de usuarios

y con extensión ejecutable al final de la ruta

AJUSTE 1 · acotar el flujo

excluir la red de servidores donde la descarga es rutina

precio: si el atacante usa un servidor interno, no alerta

AJUSTE 2 · exigir contexto

combinar con la firma de proceso hijo inusual

precio: más reglas y más costo de inspección

AJUSTE 3 · excepción explícita

pasar el flujo de la herramienta de actualización

precio: documentar y revisar la excepción con el tiempo

TODOS LOS AJUSTES SE PRUEBAN CONTRA TRÁFICO LEGÍTIMO ANTES DE ACTIVARSE EN PRODUCCIÓN

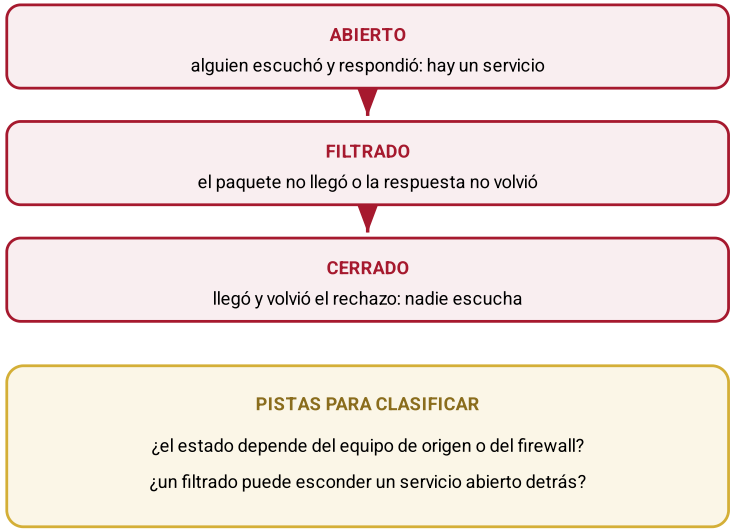
Leer un escaneo: abierto, filtrado o cerrado no es lo mismo

Escenario: salida de un escaneo; clasifique cada puerto y explique por qué.

```
# escaneo de detección de versión desde la zona de usuarios
$ nmap -sV -T3 10.10.20.10

Iniciando Nmap 7.94 ( https://nmap.org )
Nmap escaneo reportado para 10.10.20.10
Puerto        Estado     Servicio      Versión
22/tcp        abierto    ssh           OpenSSH 9.6
80/tcp        abierto    http          nginx 1.24
443/tcp       abierto    https         nginx 1.24
3306/tcp      filtrado   mysql
8080/tcp      filtrado   http-proxy
139/tcp       cerrado    netbios-ssn

Tiempo de escaneo: 12.41 segundos
```



Autenticar el escaneo cambia el reporte completo

Sin credenciales ve la superficie; con credenciales ve el estado real del parche.

NO AUTENTICADO

· Ve puertos y servicios expuestos al escáner

· Adivina versiones por la huella del servicio

· Mide la superficie visible desde la red

No distingue un servidor parchado de uno viejo

si el servicio responde igual por fuera

Útil para: perímetro y exposición

AUTENTICADO

· Lee el inventario de paquetes instalados

· Compara con el catálogo de vulnerabilidades

· Distingue el parche aplicado del faltante

Requiere credencial y agente o acceso administrativo

y un agendamiento para no afectar la operación

Útil para: parcheo y cumplimiento

ERROR TÍPICO: decir "ya escaneamos" con solo el escaneo exterior

NIST SP 800-115 (2008), §4.2 — Escaneo autenticado y no autenticado

Priorizar tres hallazgos: el orden no lo decide una sola cifra

Escenario: tres hallazgos del escaneo; elija en qué orden se parchan.

HALLAZGO 1 · web interna

biblioteca con CVE de
severidad crítica

sin explotación pública
conocida a la fecha

expuesto: solo red interna

¿primero, segundo o tercero?

HALLAZGO 2 · pasarela de pago

versión antigua con
severidad alta

aparece en el catálogo
de explotación confirmada

expuesto: cara al público

¿primero, segundo o tercero?

HALLAZGO 3 · estación de diseño

falta un parche de
severidad media

alta probabilidad de
explotación estimada

expuesto: red de oficina

¿primero, segundo o tercero?

PISTA · Combine los tres ejes: severidad técnica, explotación real y exposición propia

Y pregunte: ¿hay mitigación intermedia que compre tiempo mientras se prueba el parche?

Diagrama propio · FIRST.org CVSS v4.0 (2023) · EPSS (FIRST) · CISA KEV (catálogo vivo)

La prioridad sale del contexto, no del número de severidad

El hallazgo crítico aislado puede ir después del activo en explotación confirmada.

LA MATRIZ DE DECISIÓN QUE ORDENA LOS TRES HALLAZGOS

explotación confirmada + exposición pública > severidad aislada + exposición interna

1º · HALLAZGO 2

explotación confirmada y activo expuesto al público

2º · HALLAZGO 3

probabilidad alta y estación con correo y navegador

3º · HALLAZGO 1

crítico, pero sin explotación y sin exposición externa

MITIGACIÓN INTERMEDIA DEL 1º

· filtrar el servicio al perímetro

· restringir la pasarela a listas de origen

· monitoreo específico sobre el activo

La mitigación no cierra la grieta: compra tiempo para probar el parche sin riesgo

y deja evidencia de la gestión para el reporte interno de vulnerabilidades

ERROR TÍPICO DE ESTE EJERCICIO

· parchar por orden de severidad sola

· ignorar la exposición del activo

· dejar la mitigación sin registrar

Un comité de priorización no usa una columna de la tabla: usa las cuatro

juntas, con el negocio delante

ERRORES FRECUENTES

Los siete tropiezos del monitoreo que más se repiten

Consolidación de lo visto en la parte; cada uno con su señal de alerta temprana.

1 · Fuente silenciosa

el equipo nunca emitió eventos

señal: cero eventos

2 · Reloj desfasado

las horas no coinciden entre equipos

señal: NTP sin verificar

3 · Alerta sin contexto

el analista investiga desde cero cada vez

señal: tiempos de respuesta largos

4 · Correlación ausente

cada evento se mira en su silo

señal: patrones que nadie ve

5 · Regla sin afinar

demasiados falsos positivos

señal: alertas ignoradas

6 · Evidencia volátil

retención muy corta en el colector

señal: no hay histórico

7 · Alerta sin dueño

nadie está designado para revisarla

señal: alertas sin atender

CONSEJO DE REPASO

Antes de confiar en un SIEM, verifique estas siete señales en la red

LOS SIETE TROPIEZOS COMPARTEN UNA RAÍZ: TRATAR EL MONITOREO COMO INSTALACIÓN Y NO COMO SERVICIO

Un servicio se mide: latencia de ingesta, cobertura de fuentes, tasa de alertas atendidas y retención

Diagrama propio · consolidación de errores de la Parte 3

ERRORES FRECUENTES

Los siete tropiezos de la gestión de vulnerabilidades

El ciclo solo funciona si cada etapa tiene dueño, evidencia y fecha.

1 · Inventario incompleto

lo que no se sabe
que existe, no se parcha

señal: activos no gestionados

2 · Severidad sola

se parcha lo crítico
y se ignora lo explotado

señal: hallazgos viejos sin cerrar

3 · Escaneo sin credencial

el reporte solo ve
la superficie exterior

señal: hallazgos genéricos

4 · Parche sin prueba

se aplica directo
a producción

señal: incidentes de cambio

5 · Sin verificación

se aplica y no se
reescanea para cerrar

señal: hallazgos que reabren

6 · Excepción sin fecha

la mitigación
queda olvidada

señal: riesgo aceptado eterno

7 · Sin dueño de activo

no se sabe quién
aprueba el parche

señal: hallazgos sin responsable

LA PREGUNTA INTEGRADORA

¿Quién es el dueño
de cada activo y
quién cierra el hallazgo?

EL CICLO CIERRA CUANDO CADA ETAPA TIENE DUEÑO, EVIDENCIA Y FECHA; SI FALTA UNA, EL ANILLO SE ROMPE

En el repaso, asocie cada error a la etapa del ciclo donde ocurrió; así estudiará el proceso, no la lista

Diagrama propio · NIST SP 800-40 Rev.4 (2022) — Prácticas de parcheo

SÍNTESIS

Lo que queda de la Parte 3

Leer la red como la lee un analista: con orden, con contexto y con prioridad.

1 · Leer la bitácora

emisor, hora y mensaje;
tres alertas pueden ser una cadena

si comparten tiempo y emisor

2 · Ajustar la regla

acción, cabecera y disparador;
afinar sin romper la detección

probando contra tráfico legítimo

3 · Priorizar con contexto

severidad, explotación
y exposición propia, juntas

más la mitigación que compra tiempo

EN LA PARTE 4: UN CASO INTEGRADOR QUE CRUZA LAS CUATRO SEMANAS

Una empresa ficticia del Caribe, una cadena de ataque sencilla y las cuatro defensas de la unidad

Cerramos con la autoevaluación, la ruta de práctica y el puente a la Unidad 3

Diagrama propio · síntesis de la Parte 3

PARTE 4 DE 4

4

Caso integrador y errores frecuentes

Semana 11 · Repaso Unidad 2

Caso integrador | Errores frecuentes | Autoevaluación | Qué sigue

CUC UNIVERSIDAD DE LA COSTA

MAPA

De dónde venimos y qué haremos en el cierre

Caso integrador ficticio, consolidación de errores, autoevaluación y práctica.

PARTE 4 · CASO INTEGRADOR, ERRORES, AUTOEVALUACIÓN Y PRÁCTICA

Aplicar las cuatro semanas a una historia única de una empresa del Caribe

Caso ficticio del Caribe

una empresa, una red
y una cadena de ataque

escenario claramente ficticio

Análisis por capa

dónde falló cada control
y qué lo habría frenado

las cuatro semanas a prueba

Errores y autoevaluación

consolidación y preguntas
de control por tema

el espejo final del repaso

Práctica y puente

dos rutas guiadas
y la Unidad 3

qué sigue según el calendario

EL CASO ES FICTICIO Y ASÍ SE MARCA SIEMPRE; LOS CONTROLES Y TECNOLOGÍAS QUE APARECEN SON REALES

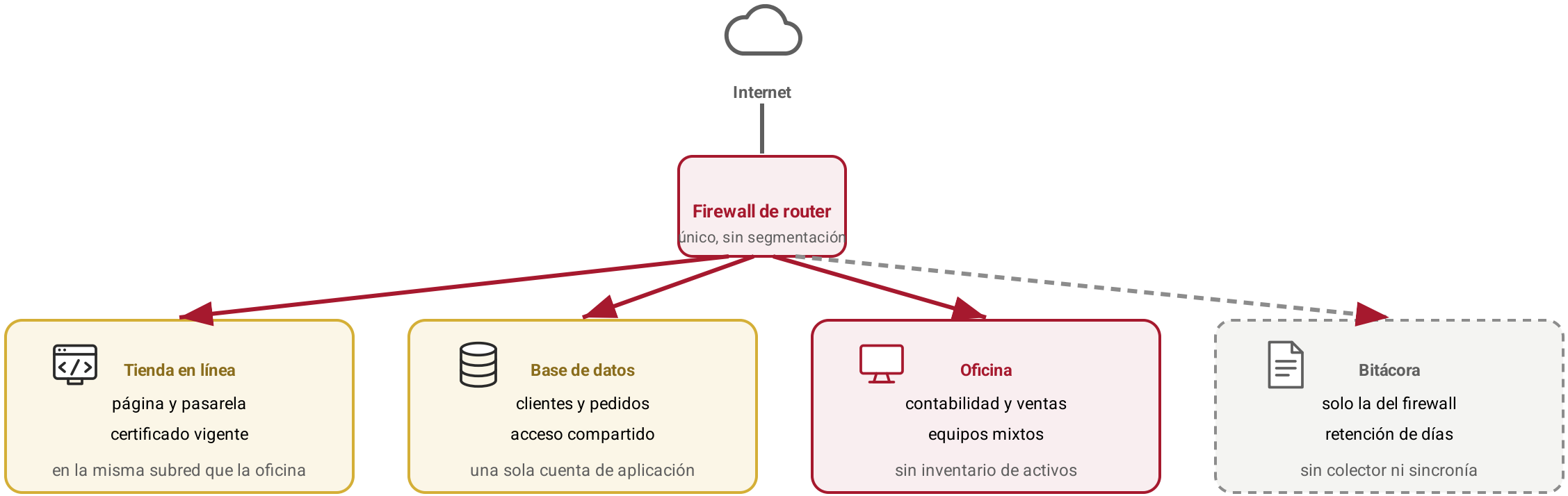
El objetivo no es asustar: es practicar el análisis con las cuatro preguntas de la Unidad 2

Diagrama propio · plan de la Parte 4

Corporación Costa Digital, Cartagena · escenario ficticio

Comercio electrónico y bodega de despacho; red pequeña, expuesta y sin dueño claro de la seguridad.

ESCENARIO FICTICIO · NO CORRESPONDE A NINGUNA EMPRESA REAL



red plana: la oficina alcanza la base de datos directamente

Escenario ficticio · diagrama propio · topología basada en el Laboratorio 1

La cadena: cinco pasos, siete días, una sola alerta ignorada

Línea de tiempo del incidente ficticio; cada paso deja su rastro en la red.

Día 1 · 09:12 — 1
correo de suplantación al área de ventas
un usuario descarga un archivo adjunto

Día 1 · 09:16 — 2
ejecución en la estación de ventas
un proceso hijo del explorador abre canal

Días 2–5 — 3
reconocimiento interno paciente
la red plana deja ver la base de datos

Día 6 · 19:40 — 4
consulta anómala sobre la base de datos
cuenta compartida, sin trazabilidad

Día 7 · 08:00 — 5
reporte de fuga de datos de clientes
sin evidencia útil para reconstruir

LO QUE LA ORGANIZACIÓN SABÍA ANTES DEL REPORTE

Alerta sin dueño
el correo rechazado existía
pero se cerró sin revisar

Sin bitácora de estación
no había agente instalado
ni registro de procesos

Sin trazabilidad en la BD
una sola cuenta compartida
para todos los sistemas

Cada paso de la cadena era visible en algún lugar; lo que faltaba era conectarlo y tener dueños.

Escenario ficticio · diagrama propio · concepto: MITRE ATT&CK® Enterprise

ANÁLISIS

Mapa de fallos: la misma cadena, vista con las cuatro preguntas

Cada etapa de la cadena se cruza con la capa de la Unidad 2 que debía sostenerla.

CRUCE DE ETAPAS DEL CASO Y CAPAS DE LA UNIDAD 2

etapa del caso	Cifrado	Identidad	Monitoreo	Vulneras
1 · Correo y adjunto	el adjunto no viajaba cifrado; nadie lo revisó	sin MFA, la clave bastó	la alerta existió, pero no tuvo dueño	el filtro era desactualizado
2 · Ejecución	no aplica directo	la sesión no se revisó	sin bitácora de proceso	el sistema no estaba endurecido
3 · Reconocimiento	la red interna no cifraba	cualquiera alcanzaba cualquier servicio	sin flujos ni NetFlow	no había segmentación
4–5 · Consulta y fuga	copia sin cifrar	cuenta compartida	sin registro de acceso	CVE antigua abierta

NINGUNA CELDA ESTÁ VACÍA: EL FUEGO CRUZADO EXPLICA POR QUÉ LA CADENA NUNCA SE DETUVO

Escenario ficticio · diagrama propio · NIST SP 800-53 Rev.5 (2020)

ANÁLISIS

Qué habría cortado cada control, con el mínimo viable

No se necesita un proyecto enorme: por capa, una medida bien puesta frena el paso crítico.

CIFRADO · mínimo viable

TLS obligatorio en la tienda y en la pasarela

y cifrado del respaldo de la base de datos

habría cortado: la fuga

IDENTIDAD · mínimo viable

MFA para acceso remoto y una cuenta por persona

en la base de datos, con permisos mínimos

habría cortado: pasos 1 y 4

MONITOREO · mínimo viable

colector de eventos con relojes sincronizados

y dueño para cada alerta

habría detectado: día 1

VULNERAS · mínimo viable

escaneo mensual con credencial y fila de

parcheo con dueño

habría cerrado: la CVE

LA LECCIÓN DEL CASO: NO FALTABAN TECNOLOGÍAS, FALTABAN DUEÑOS, RELOJES Y UNA FILA DE PARCHES

Cada mínimo viable es una tarea de semanas, no un proyecto de un año

Y los cuatro mínimos, juntos, multiplican las oportunidades de cortar la cadena

CONSOLIDACIÓN

Los doce errores que más se repiten en la Unidad 2

Cuatro por capa; el mismo patrón: confiar donde había que verificar.

CIFRADO

1 · Fiar del candado

2 · No validar el nombre

3 · Túnel sin autenticación

4 · Versiones obsoletas

raíz: confundir canal con confianza

IDENTIDAD

5 · MFA por SMS confiado

6 · Cuentas compartidas

7 · Privilegio permanente

8 · Sesión sin reevaluar

raíz: confundir inicio con identidad

MONITOREO

9 · Fuente silenciosa

10 · Reloj desfasado

11 · Alerta sin dueño

12 · Correlación ausente

raíz: confundir instalar con operar

VULNERABILIDADES

· inventario incompleto

· severidad como única guía

· sin reescaneo de cierre

raíz: confundir hallazgo con cierre

CÓMO USAR ESTA LISTA ANTES DEL EXAMEN

· No la memorice como lista: asóciela a la etapa del proceso donde ocurre cada error.

· Para cada error, pregunte: ¿qué señal lo habría revelado a tiempo? Esa señal es la que hay que monitorear.

· Y para cada capa, recuerde el mínimo viable del caso: dueño, reloj, fila de parches y trazabilidad.

Los doce errores comparten un patrón: confiar donde la Unidad 2 pedía verificar.

Diagrama propio · consolidación de errores de la Unidad 2

AUTOEVALUACIÓN

Autochequeo 1: cifrado e identidad

Doce preguntas de control; si duda en alguna, vuelva a esa diapositiva.

CIFRADO · seis preguntas

1 · ¿Qué tres cosas valida un navegador en el certificado?

2 · ¿Qué ve un intermediario de una conversación TLS?

3 · ¿Cuándo elegiría IPsec de sitio a sitio y no TLS?

4 · ¿Qué aporta WireGuard frente a IPsec en la práctica?

5 · ¿Cómo se revoca un certificado y por qué importa?

6 · ¿Qué límite del túnel explica el phishing?

Si alguna le toma más de un minuto, repase esa sección del mapa.

IDENTIDAD · seis preguntas

7 · ¿Por qué el código por SMS es un factor frágil?

8 · ¿En qué momento de un login entra el segundo factor?

9 · ¿Qué diferencia hay entre modelo por rol y por atributo?

10 · ¿Qué es el acceso justo a tiempo y cuándo se usa?

11 · ¿Qué papel juega el PEP y cuál el PDP?

12 · ¿Cómo usa 802.1X la misma arquitectura en el cable?

Si alguna le toma más de un minuto, repase esa sección del mapa.

REGLA DEL AUTOCHEQUEO: SI NO PUEDE RESPONDER EN VOZ ALTA, NO ESTÁ APRENDIDO; ESTÁ LEÍDO

Responda en voz alta, con sus palabras, sin mirar la diapositiva de origen

AUTOEVALUACIÓN

Autochequeo 2: monitoreo y vulnerabilidades

Seis preguntas por familia; el mismo criterio: respuesta en voz alta, sin mirar.

MONITOREO · seis preguntas

1 · ¿Cuáles son los seis campos de una trama de syslog?

2 · ¿Por qué el reloj decide la credibilidad de la evidencia?

3 · ¿Qué tres condiciones debe combinar una correlación útil?

4 · ¿Qué es la acción en una regla de detección?

5 · ¿Cómo ajusta un falso positivo sin romper la detección?

6 · ¿Qué papel juega el flujo de red frente a la bitácora?

Si alguna le toma más de un minuto, repase esa sección del mapa.

VULNERABILIDADES · seis preguntas

7 · ¿Qué diferencia hay entre abierto, filtrado y cerrado?

8 · ¿Qué gana y qué cuesta el escaneo autenticado?

9 · ¿Por qué la severidad sola no fija el orden de parcheo?

10 · ¿Qué es el catálogo de explotación confirmada?

11 · ¿Qué es una mitigación intermedia y para qué sirve?

12 · ¿Cuáles son las cuatro etapas del ciclo de gestión?

Si alguna le toma más de un minuto, repase esa sección del mapa.

SI COMPLETÓ LOS DOS AUTOCHEQUEOS, LO QUE SIGUE ES PRÁCTICA, NO MÁS LECTURA

En la diapositiva siguiente empieza la ruta guiada de verificación con comandos

Verificar el cifrado de un sitio: del candado a la cadena

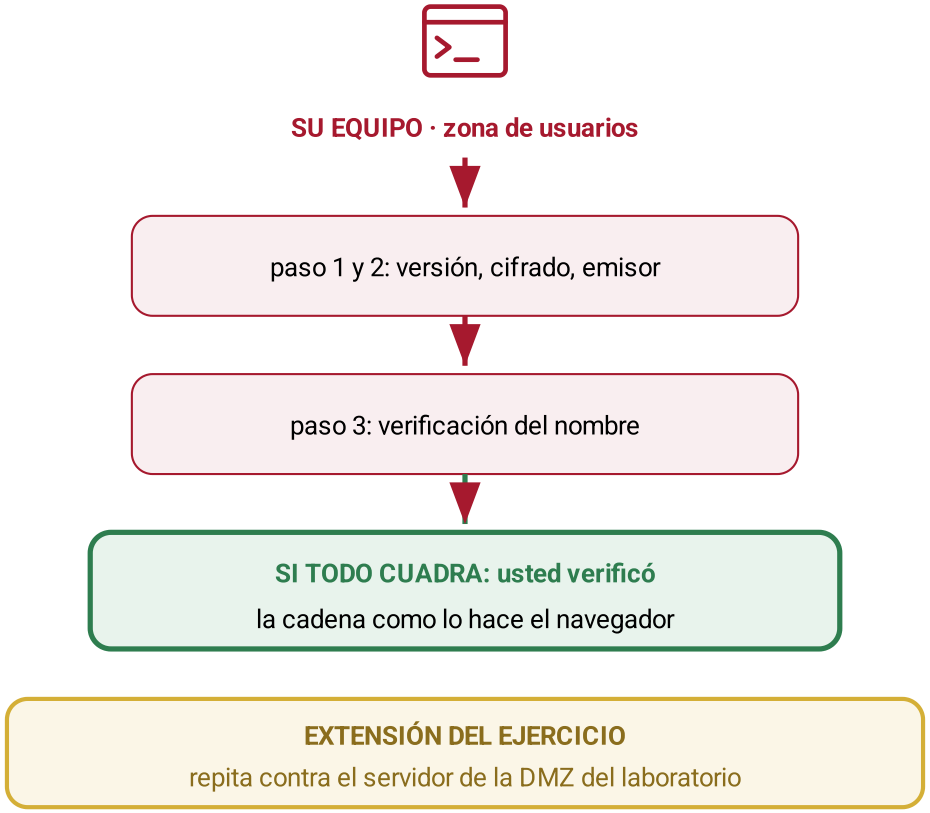
Tres comandos sobre cualquier servidor; el tercero es el que enseña a leer el certificado.

```
# 1 · versión y cifrado negociado
$ openssl s_client -connect www.example.com:443 \
    -servername www.example.com </dev/null 2>/dev/null \
    | grep -E "Protocol|Cipher is"

# 2 · emisor, sujeto y vigencia
$ openssl s_client -connect www.example.com:443 \
    -servername www.example.com </dev/null 2>/dev/null \
    | openssl x509 -noout -subject -issuer -dates

# 3 · verificación completa del nombre
$ openssl s_client -connect www.example.com:443 \
    -servername www.example.com -verify_hostname \
    www.example.com </dev/null 2>/dev/null | tail -3
```

Verificación: el tercer comando debe terminar con un mensaje de verificación correcta; si falla, el nombre no coincide.



OpenSSL Documentation · Diagrama propio — práctica sobre la topología del curso

Del escaneo a la fila de parches: priorizar sin adivinar

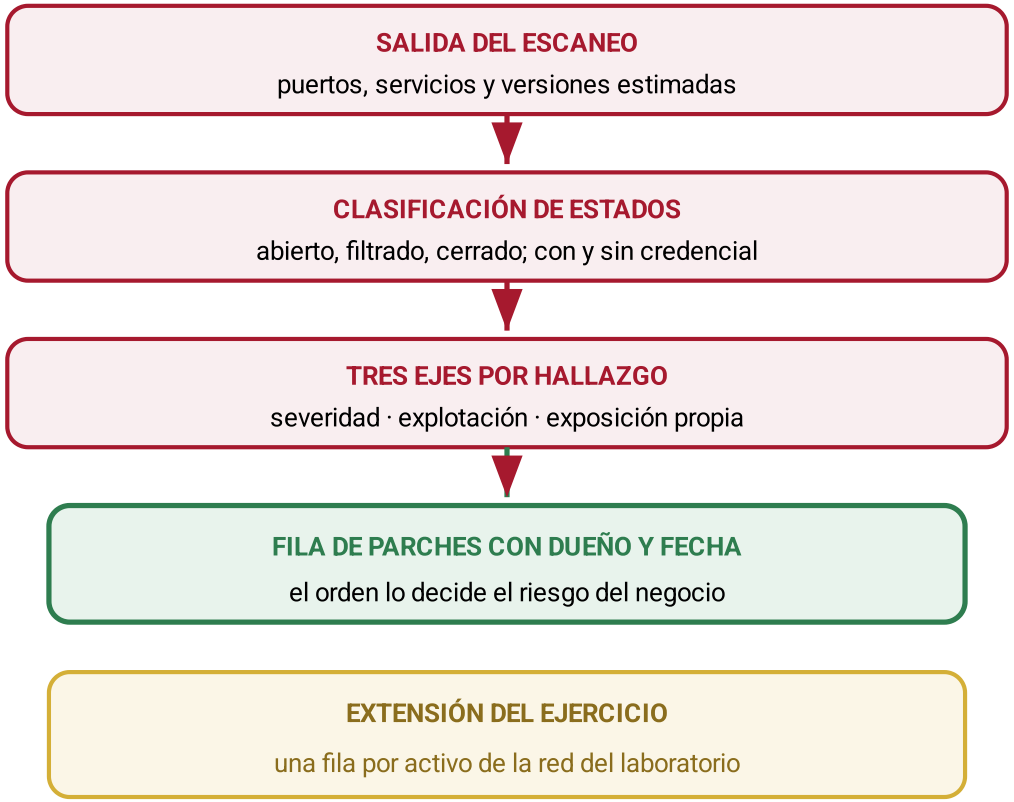
Tres pasos: escanear con detalle, clasificar estados y ordenar con los tres ejes.

```
# 1 · escaneo con detección de versión
$ nmap -sV -T3 -oN escaneo.txt 10.10.20.0/24

# 2 · solo los abiertos, con servicio
$ grep "abierto" escaneo.txt

# 3 · tabla de priorización (plantilla)
# activo | servicio | estado | expuesto
# severidad | explotación | mitigación | dueño
# ordenar por: explotación primero,
# después exposición, después severidad
```

Verificación: cada fila de la tabla debe tener dueño y fecha; sin esas dos columnas, no es una fila de parches.



CONTEXTO

Marco colombiano que acompaña la Unidad 2

Tres piezas normativas y de institución que ya aparecieron en el curso; aquí, el recordatorio.

Ley 1581 de 2012

protección de datos personales

Aplica a la base de datos de clientes del caso:

datos personales exigen medidas de seguridad

Ley 1273 de 2009

ciberdelitos y delitos informáticos

Sustenta las consecuencias penales del acceso ilícito

y de la alteración no autorizada de información

ColCERT / CSIRT

respuesta institucional

El equipo de respuesta nacional es el que puede

orientar y coordinar en incidentes de escala país

CÓMO SE TRADUCEN EN LA UNIDAD 2

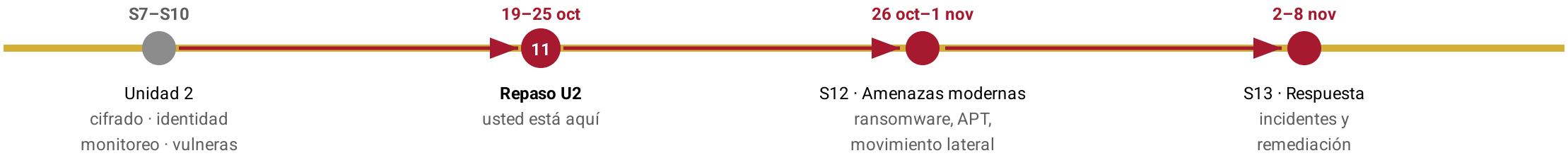
Cifrado y mínimo privilegio sostienen la confidencialidad exigida; bitácora y respuesta sostienen la trazabilidad

En el caso ficticio, los tres marcos convierten la fuga en un asunto legal, no solo técnico

PUENTE

Qué sigue: la Unidad 3 y la Semana 12

Según el calendario oficial, el repaso cierra la Unidad 2 y abre el tramo final del curso.



EL PUENTE CONCEPTUAL: LO QUE ESTUDIÓ HOY ES LA BASE DE LA SEMANA 12

La segmentación y la identidad mínima frenan el movimiento lateral; el monitoreo lo delata;

el cifrado de respaldos y la fila de parches reducen el impacto del cifrado de datos por ransomware

La Unidad 3 no reemplaza la Unidad 2: la pone a prueba con amenazas modernas

FIN DEL REPASO · BUENA SUERTE EN LA EVALUACIÓN DE LA UNIDAD 2

Referencias de la Unidad 2 y del repaso

Normas, informes y marcos citados durante las cuatro semanas y este repaso.

Cybersecurity and Infrastructure Security Agency. (s. f.). *Known Exploited Vulnerabilities Catalog*. CISA. https://www.cisa.gov/known-exploited-vulnerabilities-catalog

FIRST.org. (2023). *Common Vulnerability Scoring System v4.0*. Forum of Incident Response and Security Teams. https://www.first.org/cvss/v4.0/specification-document

FIRST.org. (s. f.). *Exploit Prediction Scoring System (EPSS)*. https://www.first.org/epss

Internet Engineering Task Force. (2008). *RFC 5280: Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile*. https://www.rfc-editor.org/rfc/rfc5280

Internet Engineering Task Force. (2009). *RFC 5424: The Syslog Protocol*. https://www.rfc-editor.org/rfc/rfc5424

Internet Engineering Task Force. (2014). *RFC 7296: Internet Key Exchange Protocol Version 2 (IKEv2)*. https://www.rfc-editor.org/rfc/rfc7296

Internet Engineering Task Force. (2018). *RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3*. https://www.rfc-editor.org/rfc/rfc8446

National Institute of Standards and Technology. (2006). *NIST Special Publication 800-92: Guide to Computer Security Log Management*. U. S. Department of Commerce.

National Institute of Standards and Technology. (2008). *NIST Special Publication 800-115: Technical Guide to Information Security Testing and Assessment*. U. S. Department of Commerce.

National Institute of Standards and Technology. (2017). *NIST Special Publication 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management*. U. S. Department of Commerce.

National Institute of Standards and Technology. (2020). *NIST Special Publication 800-207: Zero Trust Architecture*. U. S. Department of Commerce.

National Institute of Standards and Technology. (2022). *NIST Special Publication 800-40 Revision 4: Guide to Enterprise Patch Management Planning*. U. S. Department of Commerce.

Suricata. (s. f.). *Suricata Documentation — Rule Management and Rules*. Open Information Security Foundation. https://docs.suricata.io/

Congreso de la República de Colombia. (2009). *Ley 1273 de 2009*, por la cual se dictan disposiciones para la adecuación del ordenamiento jurídico penal a las nuevas tecnologías.

Congreso de la República de Colombia. (2012). *Ley 1581 de 2012*, de protección de datos personales.

CIERRE

El repaso, en una sola idea

La Unidad 2 es una conversación entre cuatro preguntas; el examen la evalúa, no la lista.



LA UNIDAD 2 SE ENTIENDE COMO CADENA Y SE EVALÚA COMO CADENA

Si recuerda las cuatro preguntas y su orden, puede reconstruir cualquier concepto de las cuatro semanas

Nos vemos en la Semana 12: Amenazas modernas de red

Diagrama propio · cierre del repaso